

IT Biztonsági Szabályzat

A Kamara információs rendszereinek, adatvagyonának és elektronikus szolgáltatásainak védelmét biztosító követelmények és eljárásrendek

KIBOCSÁTÓ	Magyar Kereskedelmi és Iparkamara 1054 Budapest, Szabadság tér 7.
JÓVÁHAGYTA	az MKIK Elnöksége
HATÁLYBA LÉPÉS	2026. január 1.
VERZIÓ / FELÜLVIZSGÁLAT	1.0 évente, illetve jelentős változás esetén
FELELŐS	IT biztonsági felelős
TERJEDELEM	10 oldal, 5 melléklettel

Tartalomjegyzék

I. Általános rendelkezések	3
1. § Cél · 2. § Háttér · 3. § Hatály · 4. § Alapelvek	3
II. Fogalmak és az információbiztonsági szervezet	4
5. § Fogalmak · 6. § Szerepkörök · 7. § Felhasználói kötelezettségek	4
III. Adatvagyon, osztályozás és kockázatkezelés	5
8. § Vagyonleltár · 9. § Adatosztályozás · 10. § Kockázatkezelés	5
IV. Hozzáférés-kezelés	6
11. § Felhasználói fiókok · 12. § Jelszó és MFA · 13. § Kiemelt jogosultságok	6
V. Végponti és hálózati biztonság	7
14. § Munkaállomások · 15. § Mobil és távmunka · 16. § Hálózat	7
VI. Levelezés, felhő, mentés és üzletmenet-folytonosság	8
17. § E-mail és adathalászat · 18. § Felhő · 19. § Mentés és helyreállítás	8
VII. Naplózás, sérülékenységek, incidenskezelés	9
20. § Naplózás · 21. § Sérülékenységek · 22. § Biztonsági események	9
VIII. Fizikai biztonság, beszállítók, oktatás, záró rendelkezések	10

A szabályzat helye a belső szabályozási rendszerben

Jelen szabályzat a Magyar Kereskedelmi és Iparkamara (a továbbiakban: **MKIK** vagy **Kamara**) információbiztonsági követelményrendszerét határozza meg. A szabályzat a GDPR 32. cikke szerinti technikai és szervezési intézkedések elsődleges belső dokumentuma, ezért az **Adatkezelési Szabályzattal** együtt alkalmazandó. Az informatikai tárgyú beszerzésekre a **Beszerzési Szabályzat**, az elektronikus iratok kezelésére a **Dokumentumkezelési Szabályzat** irányadó.

A SZABÁLYZAT KULCSÜZENETE

Az információbiztonság nem kizárólag informatikai feladat. A Kamara adatvagyonának védelméért **minden felhasználó** felelős a saját munkakörében. A szabályzat célja, hogy a védelem szintje arányban álljon a kezelt adatok érzékenységével és a Kamara közfadataiból eredő kockázatokkal.

I. Általános rendelkezések

1. § A szabályzat célja

(1) A szabályzat célja a Kamara által kezelt adatok és az azokat feldolgozó informatikai rendszerek **bizalmaságának, sértetlenségének és rendelkezésre állásának** védelme, továbbá a jogszabályi és szerződéses megfelelés biztosítása.

(2) A szabályzat meghatározza az információbiztonsági szerepköröket, a védelmi intézkedések minimumkövetelményeit, valamint a biztonsági események kezelésének rendjét.

2. § Jogszabályi és szabványi háttér

- az **(EU) 2016/679 rendelet (GDPR)**, különösen a 5., 25. és 32. cikk;
- az információs önrendelkezési jogról és az információszabadságról szóló **2011. évi CXII. törvény**;
- a kiberbiztonsági tanúsításról és felügyeletről szóló **2023. évi XXIII. törvény** és végrehajtási rendeletei – amennyiben a Kamara valamely tevékenysége a törvény hatálya alá tartozik;
- az elektronikus ügyintézésről szóló **2015. évi CCXXII. törvény**;
- az üzleti titok védelméről szóló **2018. évi LIV. törvény**;
- ajánlott jó gyakorlatként az **ISO/IEC 27001** és **ISO/IEC 27002** szabvány.

A jogszabályi hatály fennállását – különösen a kiberbiztonsági törvény szerinti bejelentési és auditkötelezettséget – az IT biztonsági felelős évente megvizsgálja, és a vizsgálat eredményét írásban rögzíti.

3. § A szabályzat hatálya

(1) **Személyi hatály:** a Kamara valamennyi munkavállalója, tisztségviselője, gyakornoka, továbbá minden olyan külső közreműködő, aki a Kamara informatikai rendszereihez hozzáférést kap.

(2) **Tárgyi hatály:** a Kamara tulajdonában vagy használatában lévő informatikai eszközök, hálózatok, alkalmazások, adatbázisok, felhőszolgáltatások és adathordozók, valamint a Kamara adatait kezelő, magántulajdonú eszközök az engedélyezett mértékben.

(3) A szabályzat előírásait a Kamara által igénybe vett külső szolgáltatókkal kötött szerződésekben – az adott szolgáltatás kockázatával arányos mértékben – érvényesíteni kell.

4. § Információbiztonsági alapelvek

1. **Szükséges ismeret elve:** hozzáférés csak a feladatellátáshoz szükséges mértékben adható.
2. **Legkisebb jogosultság elve:** minden fiók a lehető legszűkebb jogosultsággal működik.
3. **Feladatok szétválasztása:** az engedélyezés, a végrehajtás és az ellenőrzés különüljön el.
4. **Mélyiségi védelem:** több, egymástól független védelmi réteg alkalmazása.
5. **Alapértelmezett tiltás:** ami nincs kifejezetten engedélyezve, az tilos.
6. **Beépített és alapértelmezett adatvédelem:** a biztonsági követelményeket már a tervezés szakaszában érvényesíteni kell.
7. **Elszámoltathatóság:** minden lényeges művelet visszavezethető egy azonosított felhasználóra.

II. Fogalmak és az információbiztonsági szervezet

5. § Értelmező rendelkezések

Fogalom	Meghatározás
Információs vagyonelem	Minden adat, rendszer, eszköz vagy szolgáltatás, amely a Kamara működése szempontjából értéket képvisel.
Biztonsági esemény	Olyan nem kívánt vagy váratlan esemény, amely veszélyeztetheti az adatok bizalmasságát, sértetlenségét vagy rendelkezésre állását.
Biztonsági incidens	Bekövetkezett biztonsági esemény, amely tényleges kárt vagy jogsértést okozott.
Kiemelt (privilegizált) hozzáférés	Rendszergazdai vagy azzal egyenértékű jogosultság, amely a védelmi beállítások módosítására is kiterjed.
Végpont	Munkaállomás, hordozható számítógép, mobiltelefon, táblagép vagy egyéb, hálózathoz kapcsolódó eszköz.
RPO / RTO	A vállalt maximális adatvesztés, illetve a helyreállítás vállalt maximális ideje.

6. § Információbiztonsági szerepkörök

Szerepkör	Feladat- és felelősségi kör
Főtitkár	Az információbiztonságért való végső szervezeti felelősség; az erőforrások biztosítása; a maradványkockázat elfogadása.
IT biztonsági felelős	A szabályzat karbantartása; kockázatelemzés; a védelmi intézkedések megfelelőségének ellenőrzése; incidenskezelés koordinálása; éves jelentés.
IT-vezető / rendszergazda	A rendszerek üzemeltetése, a védelmi beállítások megvalósítása, mentés, naplózás, jogosultságkiosztás, javítások telepítése.
Adatgazda	Az általa kezelt adatkör osztályozása, a hozzáférési igények jóváhagyása, a jogosultságok éves felülvizsgálata.
Adatvédelmi tisztviselő	A személyes adatokat érintő intézkedések véleményezése; adatvédelmi incidens esetén a hatósági bejelentés előkészítése.
Felhasználó	A szabályzat betartása; a rábízott eszközök és hozzáférési adatok védelme; a gyanús események bejelentése.
Belső ellenőrzés	Az információbiztonsági kontrollok működésének független ellenőrzése.

7. § A felhasználók alapvető kötelezettségei

1. A Kamara informatikai eszközeit elsődlegesen munkavégzés céljából használni; magáncélú használat csak korlátozott, a biztonságot nem veszélyeztető mértékben megengedett.
2. A hozzáférési adatokat (jelszó, token, MFA-kód) **senkivel** – így a rendszergazdával sem – megosztani nem szabad.
3. A munkaállomást elhagyáskor zárolni kell; a papíralapú, érzékeny dokumentumot el kell zárni (**tiszta asztal, tiszta képernyő** elve).
4. Szoftvert telepíteni, rendszerbeállítást módosítani, biztonsági funkciót kikapcsolni tilos.
5. Bármely gyanús eseményt – kéretlen levél, váratlan jelszókérés, eszközvesztés – haladéktalanul be kell jelenteni.
6. A jogviszony megszűnésekor minden eszközt és adathordozót hiánytalanul le kell adni.

III. Adatvagyon, osztályozás és kockázatkezelés

8. § Információs vagyonleltár

- (1) Az IT-vezető naprakész **vagyonleltárt** vezet, amely tartalmazza az informatikai eszközöket, a rendszereket és alkalmazásokat, az adatbázisokat, a felhőszolgáltatásokat, valamint az egyes elemekhez rendelt adatgazdát és üzemeltetőt.
- (2) A leltárt legalább **félévente** egyeztetni kell a tényleges állapottal. Az eszközök kiadását és visszavételét átvételi elismervénnyel kell dokumentálni.
- (3) A használatból kivont adathordozókat selejtezés vagy továbbadás előtt **helyreállíthatatlanul törölni**, ennek hiányában fizikailag megsemmisíteni kell. A műveletről jegyzőkönyv készül.

9. § Adatosztályozás

Osztály	Példa	Minimális védelmi követelmény
Nyilvános	Sajtóközlemény, honlapon közzétett tartalom	Sértetlenség biztosítása; közzététel csak jóváhagyással.
Belső	Belső körlevél, munkautasítás, tervezet	Csak munkatársak számára; külső megosztás vezetői engedéllyel.
Bizalmas	Személyes adat, szerződés, ajánlat, üzleti titok	Névre szóló jogosultság, titkosított tárolás és továbbítás, naplózott hozzáférés.
Szigorúan bizalmas	Különleges adat, bérinformáció, biztonsági konfiguráció, hitelesítési adat	Szűk, névre szóló kör, MFA, fokozott naplózás, kizárólag titkosított csatornán továbbítható.

- (1) Az osztályba sorolást az **adatgazda** végzi el, és azt évente felülvizsgálja. Osztályba sorolás hiányában az adatot „**Belső**” minősítésűnek kell tekinteni.
- (2) A „Bizalmas” és „Szigorúan bizalmas” adatok a Kamara által nem engedélyezett szolgáltatásba – így nyilvános fájlmegosztóba, magánlevelezésbe vagy jóvá nem hagyott mesterséges intelligencia alapú szolgáltatásba – **nem tölthetők fel**.

10. § Kockázatkezelés

- (1) Az IT biztonsági felelős **évente legalább egyszer**, továbbá jelentős rendszerváltozás esetén kockázatelemzést készít, amely azonosítja a fenyegetéseket, a sérülékenységeket, a bekövetkezés valószínűségét és a lehetséges hatást.
- (2) A kockázatokat **kockázati nyilvántartásban** kell rögzíteni, felelőssel és határidővel ellátott kezelési intézkedéssel együtt. A magas kockázatok kezeléséről a főtitkárt tájékoztatni kell.
- (3) A megmaradó (maradvány)kockázatot a főtitkár írásban fogadja el. Új rendszer bevezetése előtt biztonsági szempontú előzetes értékelést kell végezni; ha az adatkezelés valószínűsíthetően magas kockázattal jár, **adattvédelmi hatásvizsgálatot** kell lefolytatni az Adatkezelési Szabályzat szerint.

IV. Hozzáférés-kezelés

11. § Felhasználói fiókok életciklusa

(1) Minden felhasználó **névre szóló, egyedi** fiókot kap. Közös vagy megosztott fiók használata tilos; kivételesen indokolt esetben (pl. technikai fiók) azt nyilvántartásba kell venni, felelőst kell hozzárendelni, és használatát naplózni kell.

(2) **Belépéskor** a szervezeti egység vezetője írásban igényli a hozzáféréseket; a jogosultságokat az adatgazda hagyja jóvá, az IT-vezető állítja be. Az új belépő a munkakezdés előtt információbiztonsági tájékoztatót kap, és aláírja az elfogadható használatra vonatkozó nyilatkozatot (3. melléklet).

(3) **Munkakör-változás** esetén a korábbi jogosultságokat felül kell vizsgálni és a már nem szükségeseket vissza kell vonni; a jogosultságok halmozódása nem megengedett.

(4) **Kilépéskor** valamennyi hozzáférést a jogviszony megszűnésének napján, de legkésőbb az azt követő munkanapon le kell tiltani, az eszközöket vissza kell venni, a postafiókot pedig – a vezető rendelkezése szerint – archiválni vagy átírányítani kell.

(5) A jogosultságokat az adatgazda **évente legalább egyszer** felülvizsgálja; a felülvizsgálat tényét és eredményét dokumentálni kell.

12. § Hitelesítés, jelszavak és többtényezős azonosítás

Követelmény	Előírás
Jelszó minimális hossza	Legalább 12 karakter; kiemelt jogosultságú fiók esetén legalább 16 karakter.
Összetettség	Kis- és nagybetű, szám és speciális karakter, vagy legalább négy szóból álló jelmondat.
Tiltott jelszavak	Szótári szó, név, dátum, korábban használt jelszó, ismert kiszivárgott jelszó.
Csere	Rendszeres kényszerített csere nem kötelező, de kompromittálódás gyanúja esetén azonnali .
Kezdeti jelszó	Egyszer használatos, az első bejelentkezéskor kötelező cserével.
Fiókszárolás	10 sikertelen próbálkozás után legalább 15 perc zárolás.
Többtényezős azonosítás (MFA)	Kötelező minden interneten elérhető szolgáltatásnál, távoli hozzáférésnél és minden kiemelt jogosultságú fióknál.
Tárolás	Kizárólag a Kamara által jóváhagyott jelszókezelőben; papíron, fájlban vagy böngészőprofilban nem.

13. § Kiemelt jogosultságok kezelése

(1) Kiemelt jogosultság csak névre szólóan, indokolt esetben, határozott időre adható. A rendszergazda a napi munkavégzéshez **külön, nem privilegizált** fiókot használ.

(2) A kiemelt fiókok tevékenységét fokozottan naplózni kell; a naplókat az IT biztonsági felelős **negyedévente** áttekinti.

(3) Külső szolgáltató távoli hozzáférése kizárólag előzetes engedéllyel, egyedi azonosítóval, MFA-val, időben korlátozottan és naplózott módon engedélyezhető. A hozzáférést a munka befejezésekor haladéktalanul vissza kell vonni.

V. Végponti és hálózati biztonság

14. § Munkaállomások és végpontvédelem

- (1) A Kamara valamennyi végpontján kötelező a **központilag felügyelt kártevővédelem**, a helyi tűzfal, az automatikus képernyőzár (legfeljebb 10 perc inaktivitás után) és a rendszeres biztonsági frissítés.
- (2) A hordozható eszközök tárolóját **teljes lemeztitkosítással** kell védeni. A helyreállítási kulcsokat központilag, védetten kell tárolni.
- (3) A felhasználó a munkaállomáson helyi rendszergazdai jogosultsággal nem rendelkezik. Szoftvertelepítést az IT-terület végez, kizárólag engedélyezett forrásból, licenc birtokában.
- (4) Külső adathordozó (pendrive, külső merevlemez) használata kizárólag titkosított, a Kamara által kiadott eszközzel megengedett.

15. § Mobil eszközök, távmunka és saját eszköz használata

- (1) A céges mobil eszközöket **mobileszköz-kezelő megoldás (MDM)** alá kell vonni, amely biztosítja a képernyőzárát, a titkosítást és a távoli törlés lehetőségét.
- (2) Saját eszköz (BYOD) kamarai adatok kezelésére csak az IT-vezető előzetes engedélyével, a biztonsági minimumkövetelmények teljesítése és a távoli adattörléshez való hozzájárulás esetén használható. „Szigorúan bizalmas” adat saját eszközön nem kezelhető.
- (3) Távmunka esetén a kapcsolódás kizárólag **VPN-en** keresztül, MFA-val történhet. Nyilvános, nem megbízható vezeték nélküli hálózaton kamarai rendszer csak VPN-en át érhető el. Nyilvános helyen ügyelni kell arra, hogy a képernyő tartalmát illetéktelen ne láthassa.
- (4) Az eszköz elvesztését vagy eltulajdonítását **haladéktalanul**, de legkésőbb az észleléstől számított 4 órán belül jelenteni kell az IT-területnek, amely intézkedik a hozzáférések zárolásáról és szükség esetén a távoli törlésről.

16. § Hálózatbiztonság

- (1) A Kamara hálózatát a külső hálózatoktól **tűzfalal** kell elválasztani. A tűzfalszabályokat alapértelmezett tiltás elvén kell felépitni, és legalább évente felülvizsgálni.
- (2) A hálózatot logikailag **szegmentálni** kell; el kell különíteni legalább a kiszolgálói, a munkaállomás-, a vendég- és a menedzsmenthálózatot.
- (3) A vendég vezeték nélküli hálózat a belső hálózattól elkülönül, és kizárólag internet-hozzáférést biztosít. A belső vezeték nélküli hálózat legalább WPA2-Enterprise szintű védelmet alkalmaz.
- (4) A hálózati eszközök alapértelmezett jelszavait a rendszerbe állítás előtt meg kell változtatni, a nem használt portokat és szolgáltatásokat le kell tiltani, a konfigurációkról rendszeres mentést kell készíteni.
- (5) A hálózati topológiáról és a tűzfalszabályokról naprakész dokumentációt kell vezetni. A dokumentáció „Szigorúan bizalmas” minősítésű, hozzáférése a rendszergazdákra és az IT biztonsági felelősre korlátozódik.
- (6) A távoli menedzsment felületek az internet felől közvetlenül nem tehetők elérhetővé; elérésük kizárólag VPN-en vagy ugródeszka-kiszolgálón keresztül, MFA-val engedélyezett.

VENDEGHÁLÓZAT ÉS KÜLSŐ ESZKÖZÖK

Külső fél eszköze a belső hálózatra **nem** csatlakoztatható. A tárgyalókban és a közösségi terekben kizárólag a vendég-hálózat érhető el. Az IoT- és épületfelügyeleti eszközöket önálló hálózati szegmensben kell üzemeltetni.

VI. Levelezés, felhő, mentés és üzletmenet-folytonosság

17. § Elektronikus levelezés és adathalászat elleni védelem

- (1) A kamarai levelezést kizárólag a Kamara által biztosított rendszerben lehet folytatni. A hivatalos levelezés magánfiókra történő átirányítása **tilos**.
- (2) A levelezőrendszeren kéretlen levél és kártevő elleni szűrést, valamint feladóhitelesítési ellenőrzést (SPF, DKIM, DMARC) kell működtetni.
- (3) A felhasználó nem nyithat meg ismeretlen forrásból származó mellékletet, és nem kattint gyanús hivatkozásra. Gyanú esetén a levelet **továbbítás nélkül** jelenteni kell az IT-területnek.
- (4) Fizetési adat, bankszámlaszám-változás vagy hitelesítési adat kérése esetén – függetlenül a feladó látszólagos személyétől – **második, független csatornán** (telefonos visszahívás ismert számon) kötelező az ellenőrzés a teljesítés előtt.
- (5) „Bizalmas” vagy annál érzékenyebb adat e-mailben csak titkosított csatolmányban továbbítható; a jelszót eltérő csatornán kell megküldeni.

18. § Felhőszolgáltatások

- (1) Felhőszolgáltatás használatba vétele az IT-vezető és – személyes adat kezelése esetén – az adatvédelmi tisztviselő **előzetes jóváhagyásához** kötött. A jóváhagyott szolgáltatásokról nyilvántartást kell vezetni.
- (2) A szerződésnek tartalmaznia kell az adatkezelés helyét, a titkosításra, a rendelkezésre állásra, az alvállalkozókra, az incidensbejelentésre és a szerződés megszűnéskori adatvisszaadásra vagy -törlésre vonatkozó kikötéseket.
- (3) Harmadik országba történő adattovábbítás esetén a GDPR V. fejezete szerinti garanciák meglétét igazolni kell.

19. § Mentés, helyreállítás és üzletmenet-folytonosság

Rendszerkategória	Mentés gyakorisága	RPO	RTO	Megőrzés
Kritikus (tagnyilvántartás, iratkezelő, pénzügyi rendszer)	naponta, inkrementális + heti teljes	24 óra	8 óra	30 nap napi, 12 hó havi
Fontos (levelezés, fájlszerver, intranet)	naponta	24 óra	24 óra	30 nap napi, 6 hó havi
Egyéb (teszt, segédrendszerek)	hetente	7 nap	5 munkanap	4 hét

- (1) A mentéseket a **3-2-1 elv** szerint kell kezelni: legalább három példány, két különböző adathordozón, ebből egy fizikailag elkülönített, a hálózatról leválasztott vagy módosíthatatlan (immutable) tárolón.
- (2) A mentések visszatölthetőségét **félévente legalább egyszer**, dokumentált próbahelyreállítással kell ellenőrizni. A próba eredményét az IT biztonsági felelős értékeli.
- (3) A kritikus rendszerekre üzletmenet-folytonossági és katasztrófa-helyreállítási tervet kell készíteni, amely tartalmazza az értesítési láncot, a helyreállítás lépéseit és az ideiglenes munkavégzés rendjét. A tervet évente felül kell vizsgálni és gyakorolni kell.

VII. Naplózás, sérülékenységszűrés, incidenskezelés

20. § Naplózás és monitorozás

(1) Naplózni kell legalább a sikeres és sikertelen bejelentkezéseket, a jogosultság-változásokat, a kiemelt jogosultságú műveleteket, a biztonsági beállítások módosítását, a „Bizalmas” és annál érzékenyebb adatokhoz való hozzáférést, valamint a rendszerhibákat.

(2) A naplóbejegyzés tartalmazza az esemény idejét, a felhasználó azonosítóját, a forrás azonosítóját, az esemény típusát és eredményét. A naplók **utólag nem módosíthatók**, és az adminisztrátorok által nem törölhetők.

(3) A naplókat legalább **12 hónapig** meg kell őrizni. A naplókban szereplő személyes adat kizárólag biztonsági célból, a jogosultak szűk körében kezelhető; a napló nem használható a munkavégzés általános, folyamatos megfigyelésére.

21. § Sérülékenységszűrés és javítások

Súlyosság	Javítás határideje	Eljárás
Kritikus	72 óra	Soron kívüli telepítés; ha nem lehetséges, kompenzáló kontroll és vezetői tájékoztatás.
Magas	14 nap	Tervezett telepítés, tesztelést követően.
Közepes / alacsony	90 nap	Rendes karbantartási ciklusban.

(1) Az IT-terület figyelemmel kíséri a gyártói és hatósági sérülékenységi közleményeket, és legalább **negyedévente** sérülékenységvizsgálatot végez a kritikus rendszereken.

(2) A támogatás nélküli (lejáró életciklusú) szoftverek és eszközök használatát meg kell szüntetni; ha ez átmenetileg nem lehetséges, elkülönítéssel és kompenzáló kontrollal kell a kockázatot csökkenteni.

22. § Biztonsági események és incidensek kezelése

(1) Minden felhasználó köteles a biztonsági eseményt **haladéktalanul** bejelenteni az IT-területnek vagy az IT biztonsági felelősnek, az 4. melléklet szerinti bejelentő lapon vagy a kijelölt címen.

(2) Az incidenskezelés lépései: **bejelentés** → **azonosítás és besorolás** → **elszigetelés** → **felszámolás** → **helyreállítás** → **utólagos értékelés**. Minden lépést idővonallal együtt dokumentálni kell.

(3) Ha az esemény **személyes adatot** érint, az IT biztonsági felelős haladéktalanul értesíti az adatvédelmi tisztviselőt. Az adatvédelmi incidenst az Adatkezelési Szabályzat szerint kell kezelni, ideértve a felügyeleti hatóság **72 órán belüli** értesítését, ha a bejelentés feltételei fennállnak.

(4) Bűncselekmény gyanúja esetén a főtitkár dönt a feljelentésről. A bizonyítékokat – naplók, lemezképek – változatlan formában, dokumentált módon kell megőrizni.

(5) Az incidensekről nyilvántartást kell vezetni; a lezárt incidensek tanulságait be kell építeni a kockázatelemzésbe és az oktatási anyagokba.

VIII. Fizikai biztonság, beszállítók, oktatás és záró rendelkezések

23. § Fizikai és környezeti biztonság

- (1) A kiszolgálóhelyiséghez és a hálózati elosztókhoz kizárólag a névre szólóan feljogosított személyek férhetnek hozzá; a belépést naplózni kell. Külső személy csak kísérettel léphet be.
- (2) A kiszolgálóhelyiségben biztosítani kell a szünetmentes áramellátást, a megfelelő hűtést, valamint a tűz- és vízbetörés elleni védelmet. A környezeti paramétereket felügyelni kell.
- (3) A papíralapú, „Bizalmas” vagy annál érzékenyebb dokumentumokat zárható szekrényben kell tárolni, selejtezéskor iratmegsemmisítővel kell megsemmisíteni.
- (4) Az informatikai eszközök épületből történő kivitelét – a rendszeresített hordozható eszközök kivételével – engedélyhez és nyilvántartásba vételhez kell kötni.

24. § Beszállítói és harmadik feles biztonság

- (1) Informatikai szolgáltatás igénybevétele előtt a szolgáltató biztonsági megfelelőségét értékelni kell (tanúsítványok, referenciák, alvállalkozói lánc, székhely szerinti joghatóság).
- (2) A szerződésnek tartalmaznia kell a titoktartást, a biztonsági követelményeket, az incidensbejelentési kötelezettséget és határidejét, az ellenőrzési jogot, valamint a szerződés megszűnéskori adatvisszaadás és -törlés rendjét.
- (3) A szolgáltató munkatársai a Kamara rendszereihez csak névre szóló azonosítóval, a 13. § (3) bekezdése szerinti feltételekkel férhetnek hozzá. A szolgáltatói hozzáféréseket az IT-vezető negyedévente felülvizsgálja.

25. § Oktatás, ellenőrzés, felelősség

- (1) Minden munkatárs belépéskor, majd **évente** információbiztonsági oktatáson vesz részt; a részvételt dokumentálni kell. Évente legalább egy alkalommal szimulált adathalász-gyakorlatot kell tartani, kizárólag oktatási céllal, egyéni szankció alkalmazása nélkül.
- (2) Az IT biztonsági felelős évente írásbeli beszámolót készít a főtitkárnak az információbiztonság helyzetéről, az incidensekről és a tervezett fejlesztésekről.
- (3) A szabályzat megsértése munkajogi következményt von maga után, és megalapozhatja a kártérítési, illetve büntetőjogi felelősséget. Külső közreműködő esetén a szerződésben rögzített jogkövetkezmények alkalmazandók.

26. § Hatálybalépés és mellékletek

Jelen szabályzat **2026. január 1-jén** lép hatályba. Felülvizsgálatáról az IT biztonsági felelős évente, továbbá jelentős technológiai, szervezeti vagy jogszabályi változás esetén soron kívül gondoskodik.

Mellékletek: 1. sz. Jelszó- és hitelesítési követelmények részletes leírása · 2. sz. Adatosztályozási útmutató és kezelési mátrix · 3. sz. Elfogadható használatra vonatkozó nyilatkozat · 4. sz. Biztonsági esemény bejelentő lap · 5. sz. Mentési és helyreállítási mátrix

elnök

Magyar Kereskedelmi és Iparkamara

főtitkár

Magyar Kereskedelmi és Iparkamara